

# DEVDATE PLATFORM — POST-FIX AUDIT REPORT

**STATUS:**  
**READY FOR DEPLOYMENT**  
Audit Date: Sept 2026

Comprehensive Security Verification, Contract Compliance & Production Readiness

|                |                |                 |                 |                   |
|----------------|----------------|-----------------|-----------------|-------------------|
| 100%           | 0              | 0               | 41 / 41         | VERIFIED          |
| PREVIOUS FIXES | CRITICAL VULNS | HIGH / MED BUGS | AUTOMATED TESTS | ATLAS TTL INDEXES |

## 1. Verification of Previous Audit Findings

| Finding / Vulnerability          | Prev Severity | Current Status | Verification Evidence & Verification Logic                                                                                                                   |
|----------------------------------|---------------|----------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|
| x-user-id Authentication Bypass  | CRITICAL      | RESOLVED       | Guarded behind process.env.NODE_ENV !== 'production' in auth.js & sockets/index.js. npm run test:auth verified 12/12 test cases pass.                        |
| Helmet & CORS Origin Lockdown    | HIGH          | RESOLVED       | Registered helmet() security headers in app.js; replaced wildcard CORS with strict origin validation in cors.js. npm run test:security verified 21/21 tests. |
| Production Environment Variables | HIGH          | RESOLVED       | Startup validator in config/env.js enforces MONGO_URI, JWT_SECRET, REFRESH_TOKEN_SECRET, BREVO_API_KEY. Sanitized .env.example.                              |
| EXPO_PUBLIC_API_URL Resolution   | MEDIUM        | RESOLVED       | Centralized in app/utils/api.js (getApiBaseUrl(), getSocketBaseUrl()) and consumed by AppContext.js for HTTP and WebSockets.                                 |
| 14-Minute Keep-Alive Workflow    | MEDIUM        | RESOLVED       | Workflow at .github/workflows/keep-alive.yml scheduled with */14 **** targeting GET /health via secrets.KEEP_ALIVE_URL.                                      |
| MongoDB TTL Indexes Verification | MEDIUM        | RESOLVED       | Verified active TTL indexes (expiresAt_1, expireAfterSeconds: 0) directly against live MongoDB Atlas cluster for sessions, emailotps, and passwordresets.    |

## 2. Empirical Automated Test Suite Verification

| Test Suite Command     | Focus Domain                                    | Tests Executed       | Result    | Status Summary                                                                                |
|------------------------|-------------------------------------------------|----------------------|-----------|-----------------------------------------------------------------------------------------------|
| npm run test:auth      | Authentication & x-user-id Production Rejection | 12 / 12 Passing      | 100% PASS | Strict 401 on unauthorized header fallback in production; dev mode permitted.                 |
| npm run test:security  | Helmet HTTP Security Headers & Production CORS  | 21 / 21 Passing      | 100% PASS | OWASP security headers active; untrusted browser origins blocked; mobile bypass working.      |
| npm run test:ratelimit | Per-Account Exponential Backoff & Route Limits  | 5 / 5 Passing        | 100% PASS | Backoff factor 2x enforced on auth routes; public & user action limiters functioning.         |
| npm run test:tll       | MongoDB Atlas Live TTL Index Verification       | 3 / 3 Models Passing | 100% PASS | Session, EmailOTP, and PasswordReset TTL indexes verified in Atlas with expireAfterSeconds=0. |

3. Production Readiness Audit Matrix

| Evaluation Dimension             | Evaluation Standard & Verification Detail                                                                                                                                              | Verdict |
|----------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------|
| Authentication Engine            | JWT Access tokens (15m), sliding Refresh tokens (7d), SHA-256 session rotation, bcrypt password hashing, single-use 6-digit OTPs (10m) and single-use crypto reset tokens (15m).       | PASS    |
| Authorization & Access Control   | Project ownership enforced for project updates/deletions/invitations. Recipient validation enforced for invitation acceptance. Strict participant authorization for 1-to-1 chat rooms. | PASS    |
| Database & Storage Layer         | MongoDB Atlas schemas synchronized; TTL indexes active on temporary collections; lean queries with projection minimization to prevent data leakage.                                    | PASS    |
| API Routing & Rate Limiting      | Strict tiered rate limiting: (1) Auth limiter with exponential delay, (2) Public limiter 100 req/15m, (3) User action limiter 1000 req/15m. Centralized Express error handler.         | PASS    |
| Socket.IO Real-Time Engine       | JWT handshake verification in production; room isolation (match:<id>, user:<id>); authorization checks before message storage and broadcasts.                                          | PASS    |
| Frontend React Native Client     | Lightweight native fetch wrapper with centralized Authorization injection; automatic 401 token refresh queue; avatar fallback resolvers; complete error/empty/loading UI states.       | PASS    |
| Environment & Secrets Safety     | No hardcoded secrets or credentials; .env ignored by Git; mandatory variables validated at startup; sanitized .env.example templates provided.                                         | PASS    |
| HTTP & Transport Security        | Helmet security headers registered (CSP, X-Content-Type-Options, X-Frame-Options, Referrer-Policy); CORS whitelisting; trust proxy configured for reverse proxies.                     | PASS    |
| External 14-Min Keep-Alive       | GitHub Actions workflow scheduled at */14 * * * * pinging GET /health with 15s timeout to prevent Render free instance idle sleep.                                                     | PASS    |
| Dependency & Vulnerability Audit | npm audit on backend reports <b>0 vulnerabilities</b> . Frontend dev dependencies validated with no critical/high issues.                                                              | PASS    |

4. Pre-Launch Operations & Final Deployment Guide

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <p><b>1. Render Production Environment</b></p> <p>Set the following Environment Variables in Render Dashboard:</p> <ul style="list-style-type: none"><li>NODE_ENV=production</li><li>MONGO_URI=&lt;Your-Atlas-Connection-String&gt;</li><li>JWT_SECRET=&lt;Cryptographically-Secure-Secret&gt;</li><li>REFRESH_TOKEN_SECRET=&lt;Secure-Refresh-Secret&gt;</li><li>BREVO_API_KEY=&lt;Your-Brevo-API-Key&gt;</li><li>ALLOWED_ORIGINS=https://your-domain.com</li></ul> | <p><b>2. GitHub Keep-Alive Secret</b></p> <p>Configure repository secret for 14-min keep-alive ping:</p> <ul style="list-style-type: none"><li>Go to: <b>Repo Settings &gt; Secrets &gt; Actions</b></li><li>Key: KEEP_ALIVE_URL</li><li>Value: https://&lt;your-render-app&gt;.onrender.com/health</li></ul> <p><b>3. Mobile App Release Build</b></p> <ul style="list-style-type: none"><li>Set EXPO_PUBLIC_API_URL=https://&lt;render-app&gt;.onrender.com/api</li><li>Run eas build --platform android to generate APK.</li></ul> |
|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|